



NCA Sponsored Training

Day 3 – Morning Session (Theory)

Network Security 1

Ahmed Didouh

Madinah

14/01/2026



rc3.kaust.edu.sa





Outline



1. Background

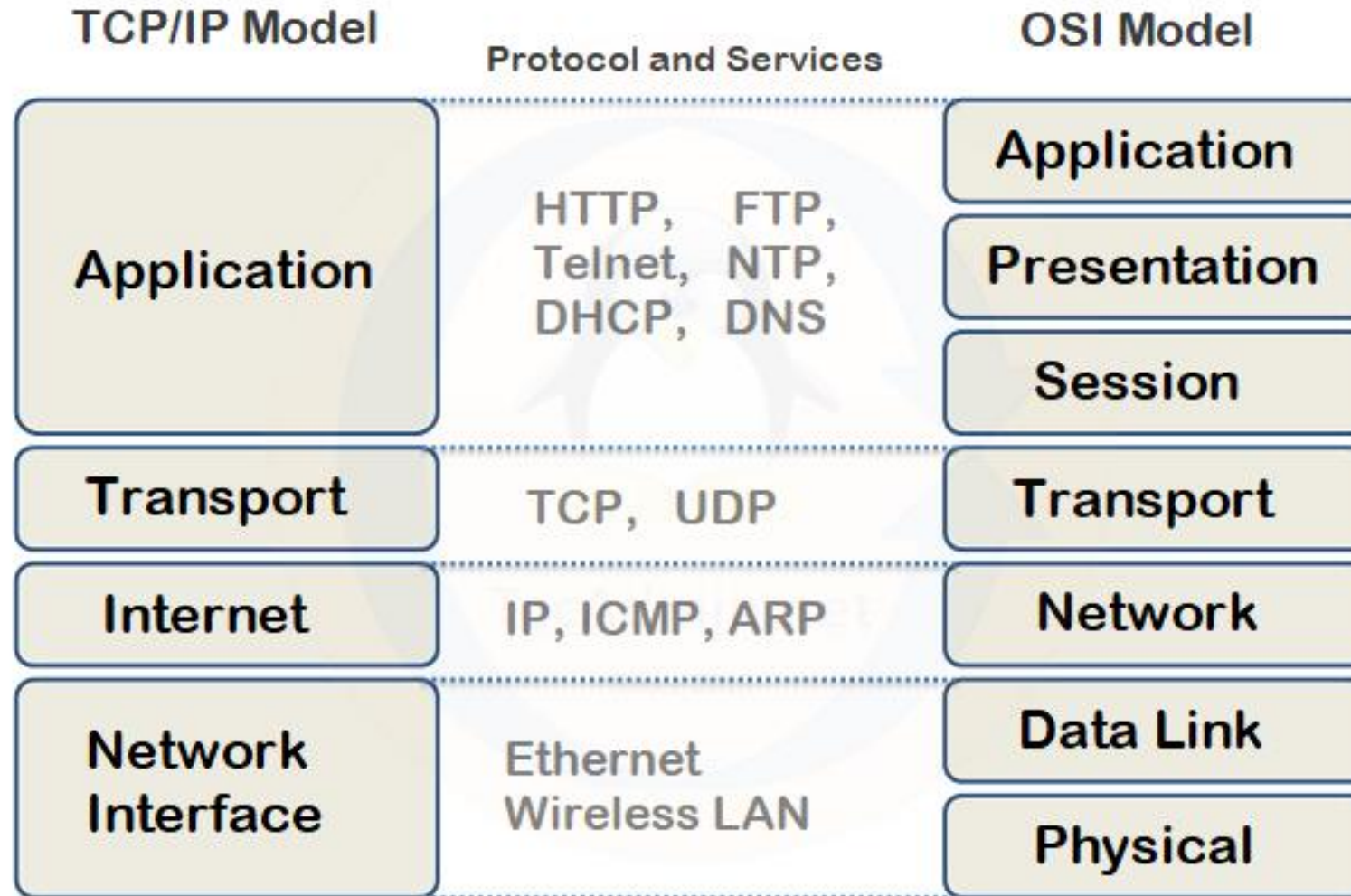
- *Network stack*
- *TCP/IP Stack*

2. Network Security

- *TCP/IP*
- *ARP*
- *Routing*
- *DNS*

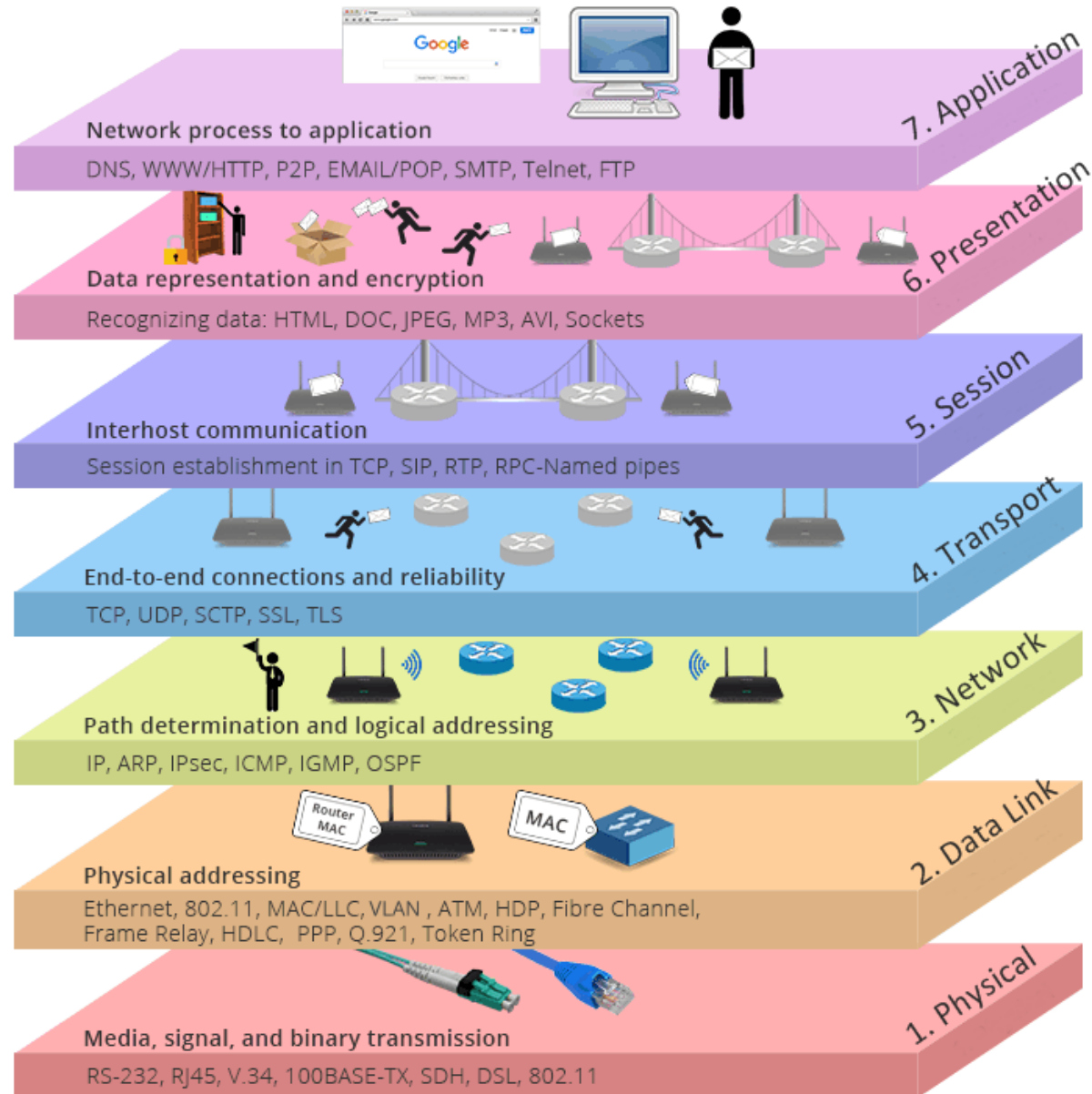


Network Protocols Stack



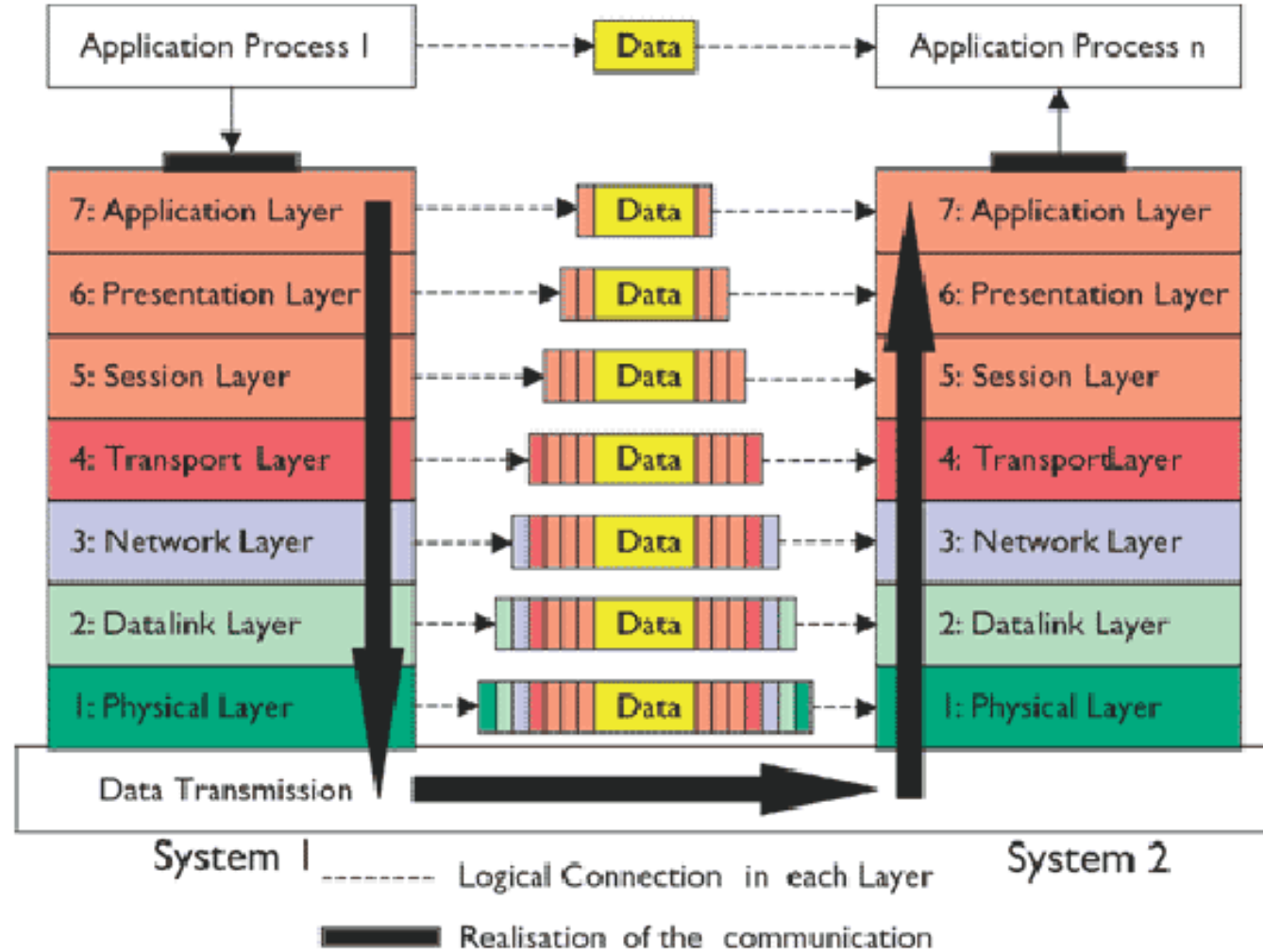


Network Protocols Stack



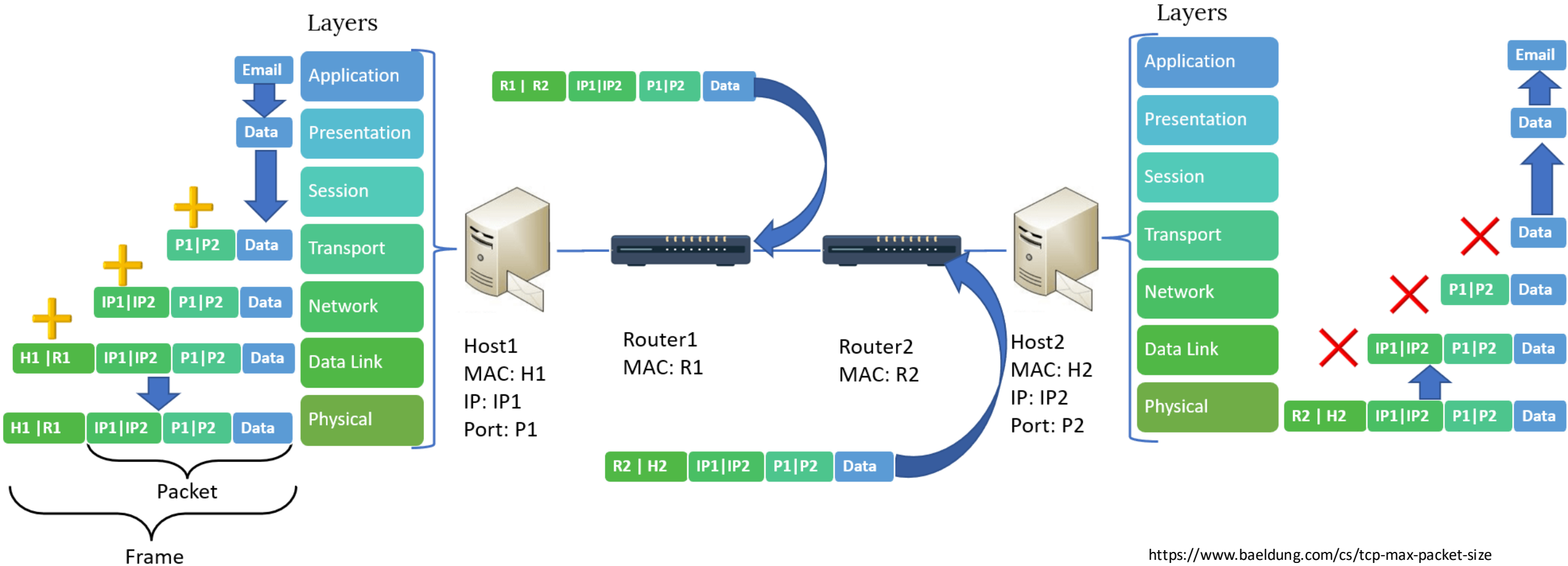


Network metadata at each layer





The data journey

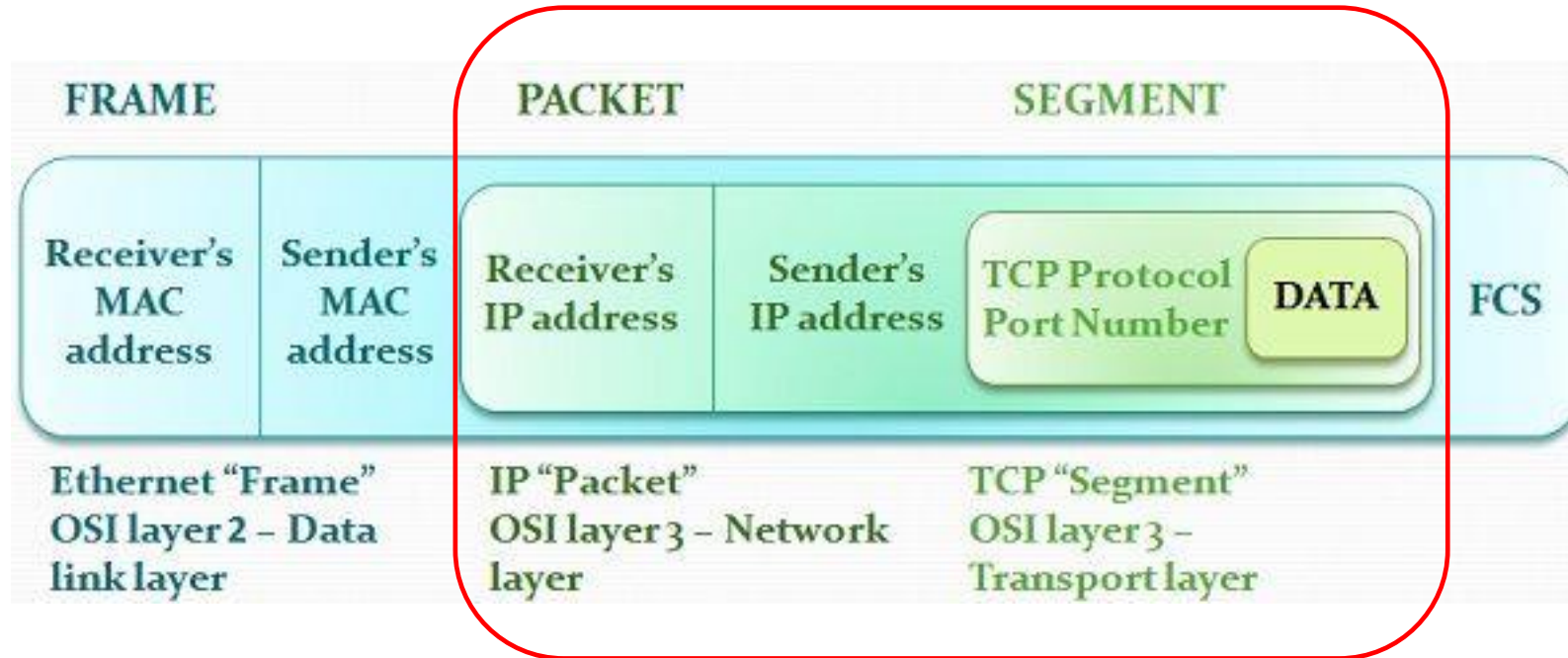




Network: lots of “packet” encapsulation



Our focus





Transport vs. network layer services and protocols



- **transport layer:**
communication between *processes*
 - relies on, enhances, network layer services
- **network layer:**
communication between *hosts*

household analogy:

12 kids in Ann's house sending letters to 12 kids in Bill's house:

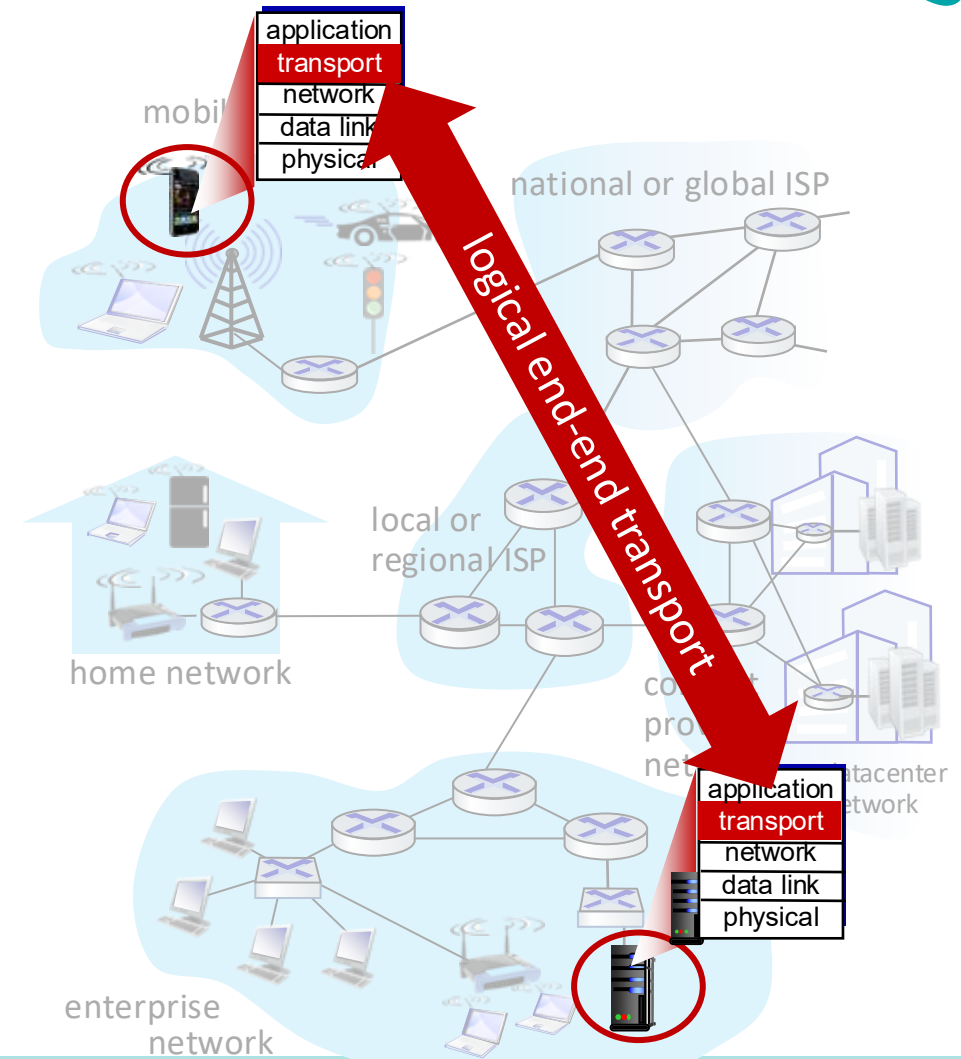
- hosts = houses
- processes = kids
- app messages = letters in envelopes
- **transport protocol** = Ann and Bill who demux to in-house siblings
- network-layer protocol = postal service



Transport Services and Protocols



- provide *logical communication* between application processes running on different hosts
- transport protocols actions in end systems:
 - sender: breaks application messages into *segments*, passes to network layer
 - receiver: reassembles segments into messages, passes to application layer
- two transport protocols available to Internet applications
 - TCP, UDP





Two principal Internet transport protocols

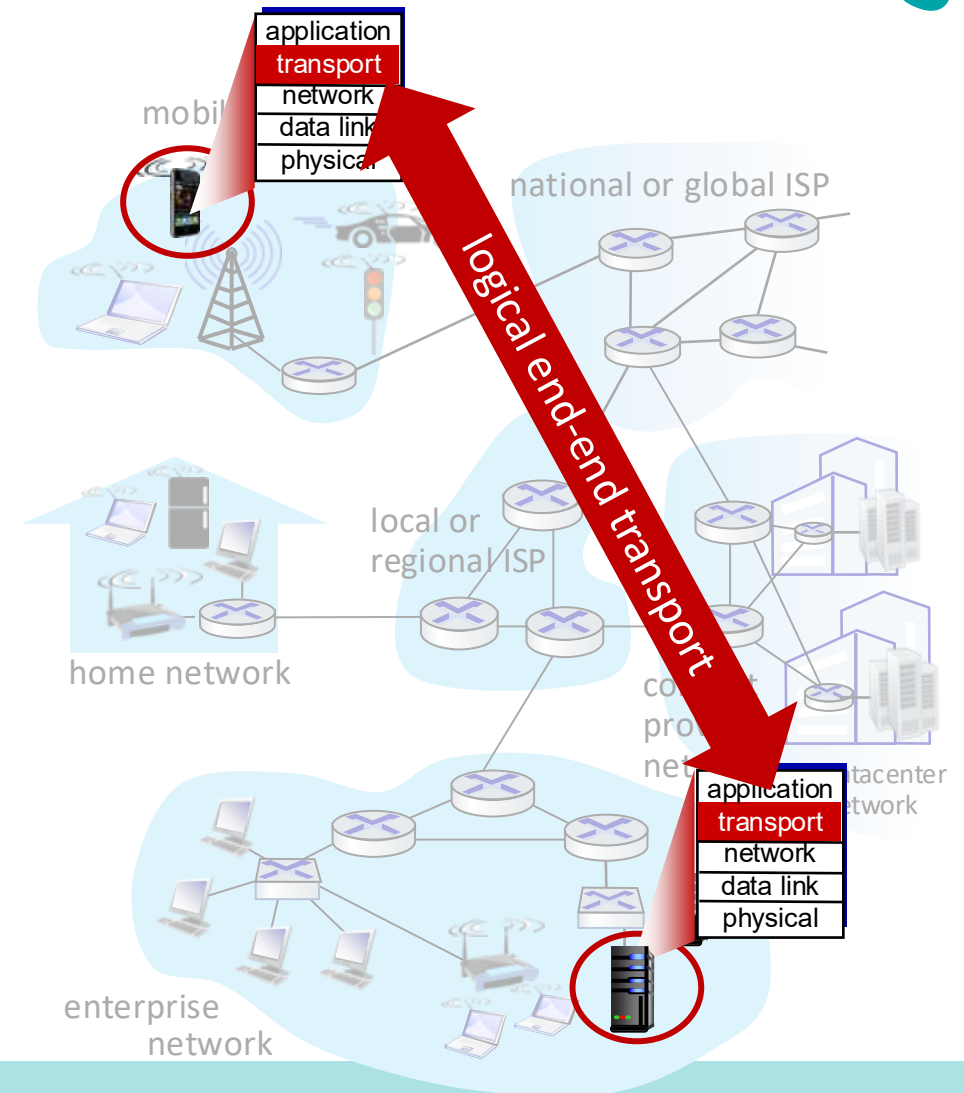


■ **TCP:** Transmission Control Protocol

- Reliable (exactly-once delivery)
- In-order delivery
- connection setup
- E.g. emails, web browsing

■ **UDP:** User Datagram Protocol

- unreliable, unordered delivery
- no-frills extension of “best-effort” IP
- E.g., audio/video streaming



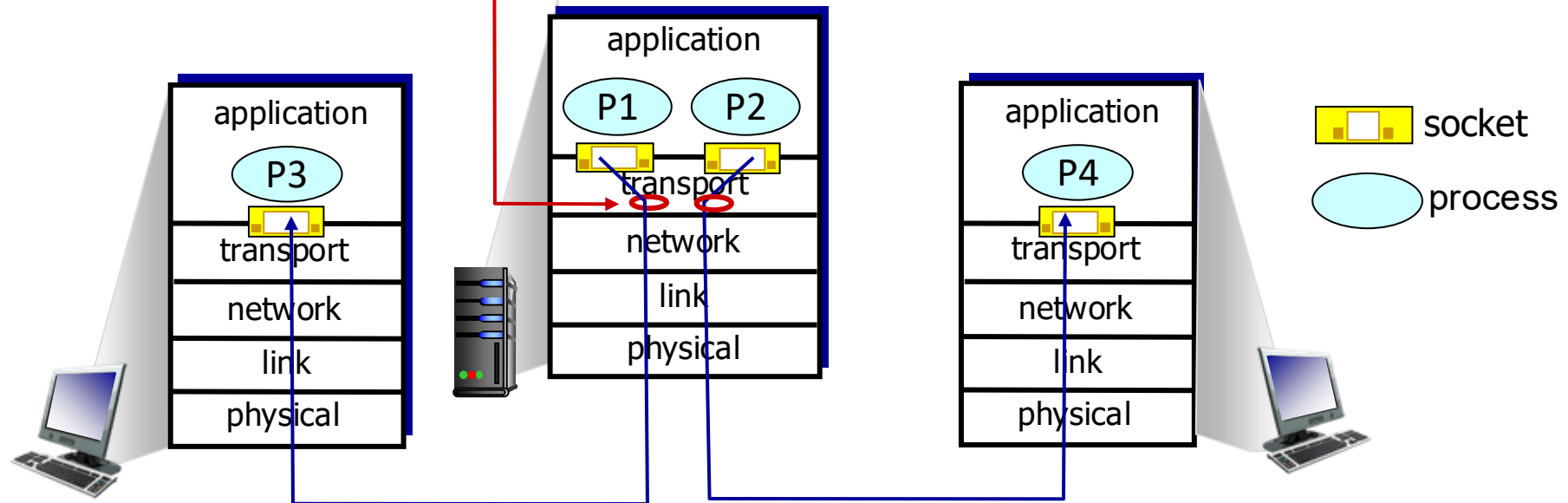


Multiplexing/Demultiplexing



multiplexing as sender:

handle data from multiple sockets, add transport header (later used for demultiplexing)



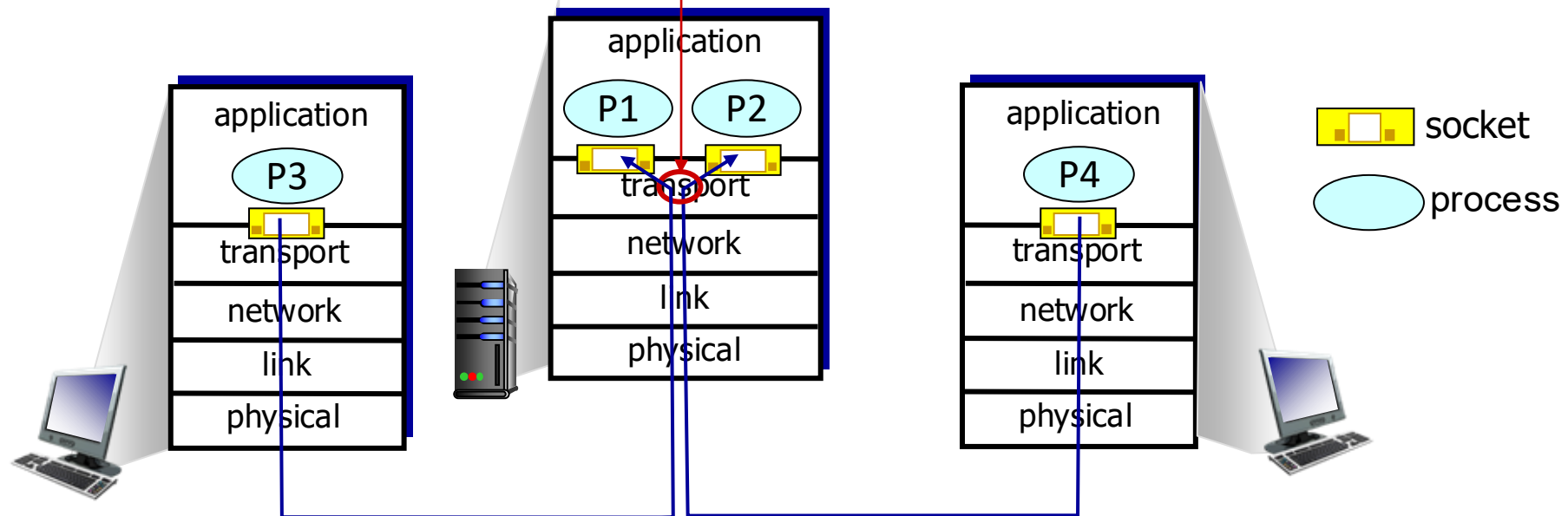


Multiplexing/Demultiplexing



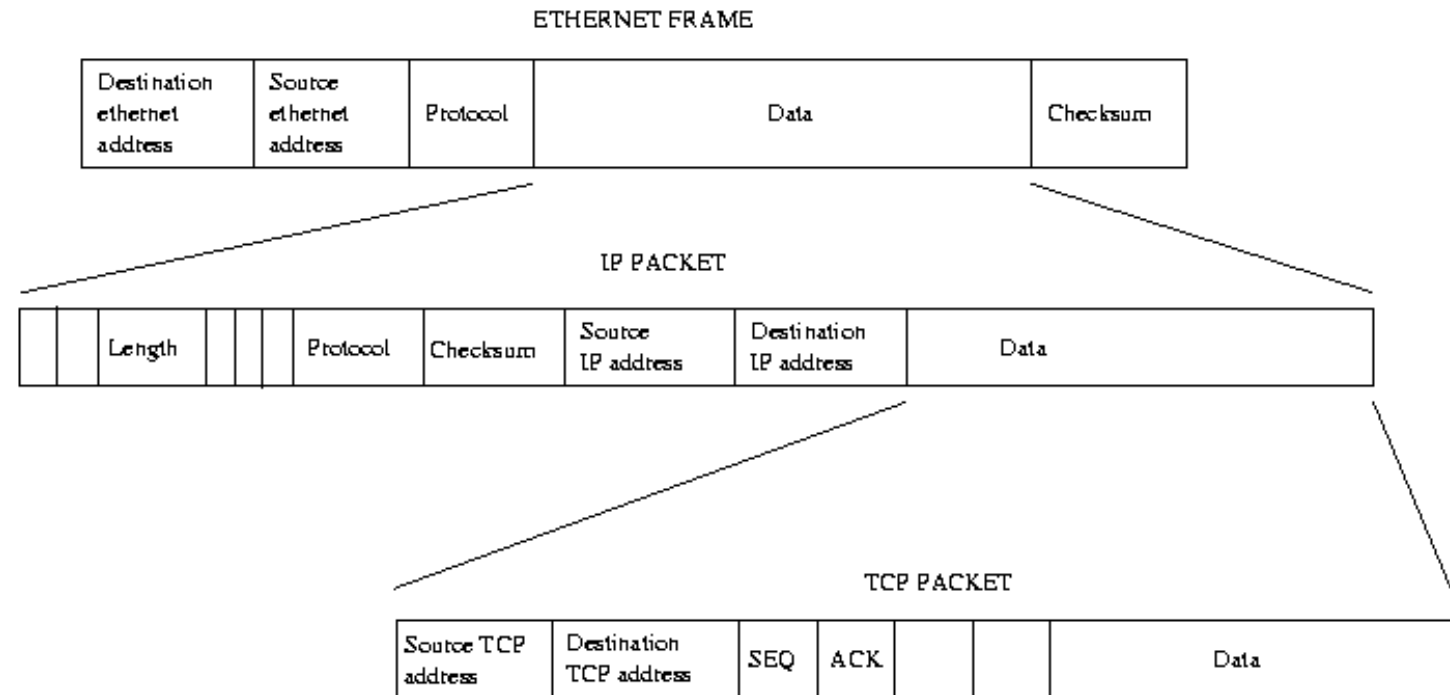
demultiplexing as receiver:

use header info to deliver
received segments to correct
socket



- host receives Ethernet Frame through PHY
- Frame carries IP packet with **source IP address**, **destination IP address**
- IP packet carries one transport-layer (e.g., TCP) segment/packet
- each segment has **source and destination port number**
- host uses IP addresses & port numbers to direct segment to appropriate port (socket)

Multiplexing/Demultiplexing



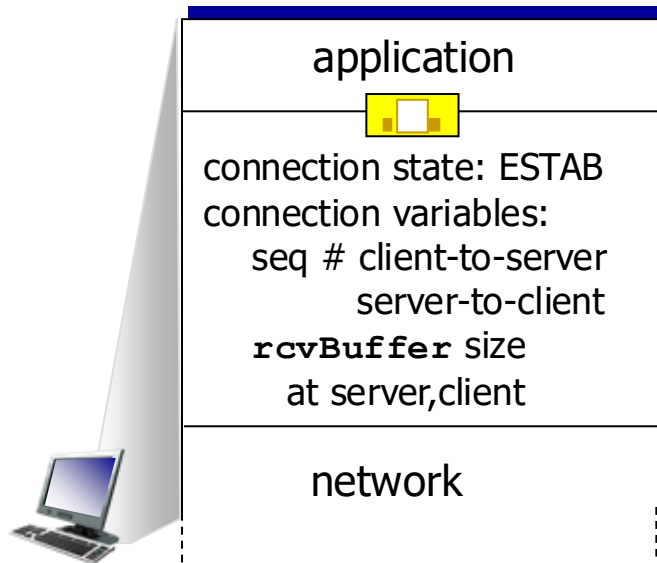


TCP Handshake

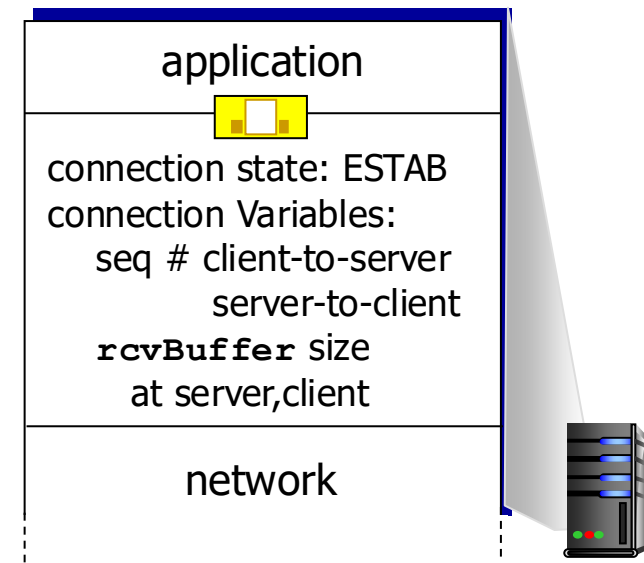


before exchanging data, sender/receiver “handshake”:

- agree to establish connection (each knowing the other willing to establish connection)
- agree on connection parameters (e.g., starting seq #s)



```
Socket clientSocket =  
    newSocket("hostname", "port number");
```



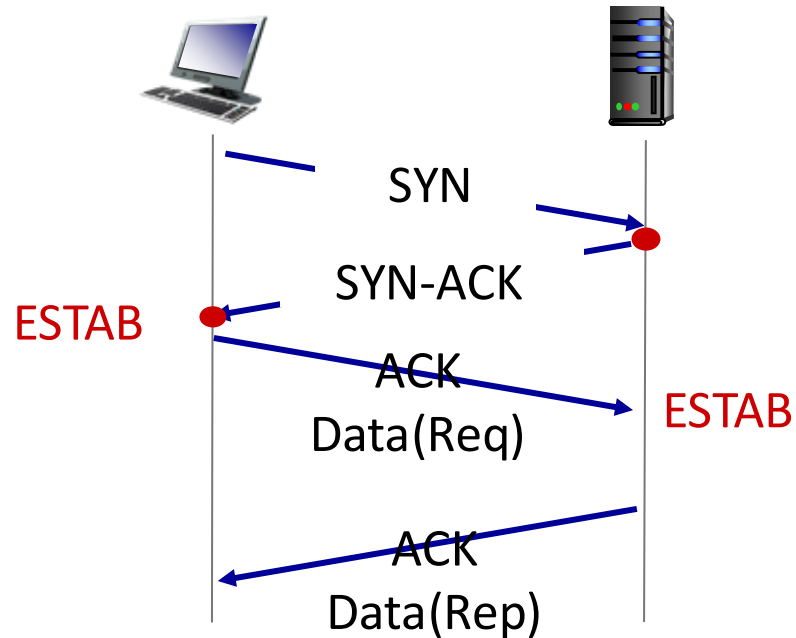
```
Socket connectionSocket =  
    welcomeSocket.accept();
```



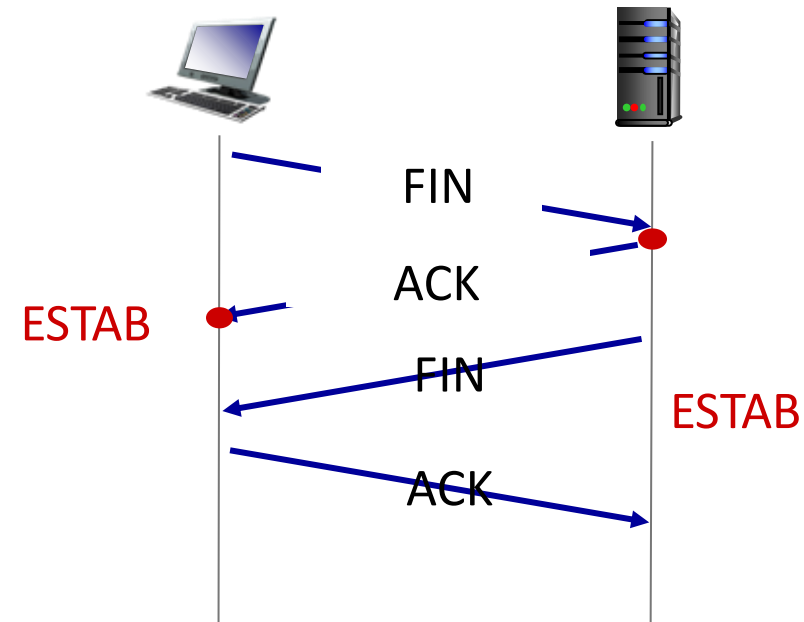
Agreeing to establish a connection



3-way handshake Connection



4-way handshake Termination





Network Security



- Internet not originally designed with (much) security in mind
 - *original vision*: “a group of mutually trusting users attached to a transparent network” 😊
 - Internet protocol designers playing “catch-up”
 - security considerations in all layers!
- We now need to think about:
 - how bad guys can attack computer networks
 - how we can defend networks against attacks
 - how to design architectures that are immune to attacks



Threats in Networking



- **Confidentiality**

- Packet Sniffing

- **Integrity**

- Session Hijacking

- **Availability**

- Denial of Service attacks

- **Common**

- Address translation poisoning attacks
- Routing attacks



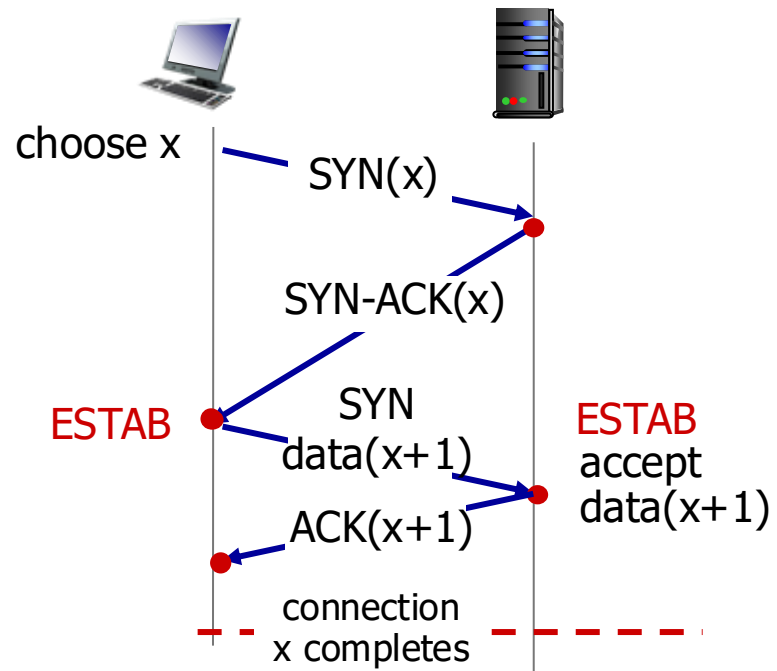
Concrete Security Problems



- ARP is not authenticated
 - ARP *Spoofing* (or ARP *Poisoning*)
- Network packets pass by untrusted hosts
 - Packet *sniffing*
- TCP state can be easy to guess
 - TCP Spoofing attack
- Common
 - Address translation poisoning attacks
 - Routing attack
- Open Access
 - Vulnerable to DoS Attacks
- DNS is not authenticated
 - DNS poisoning attacks



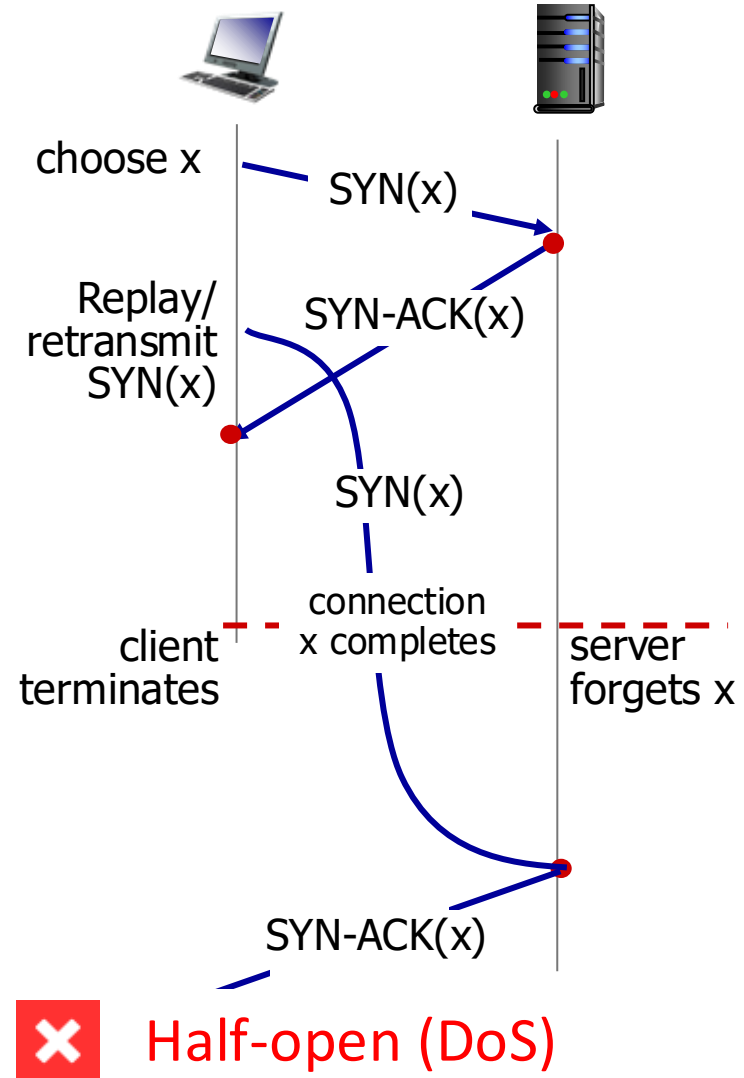
TCP handshake attack scenarios



No problem!

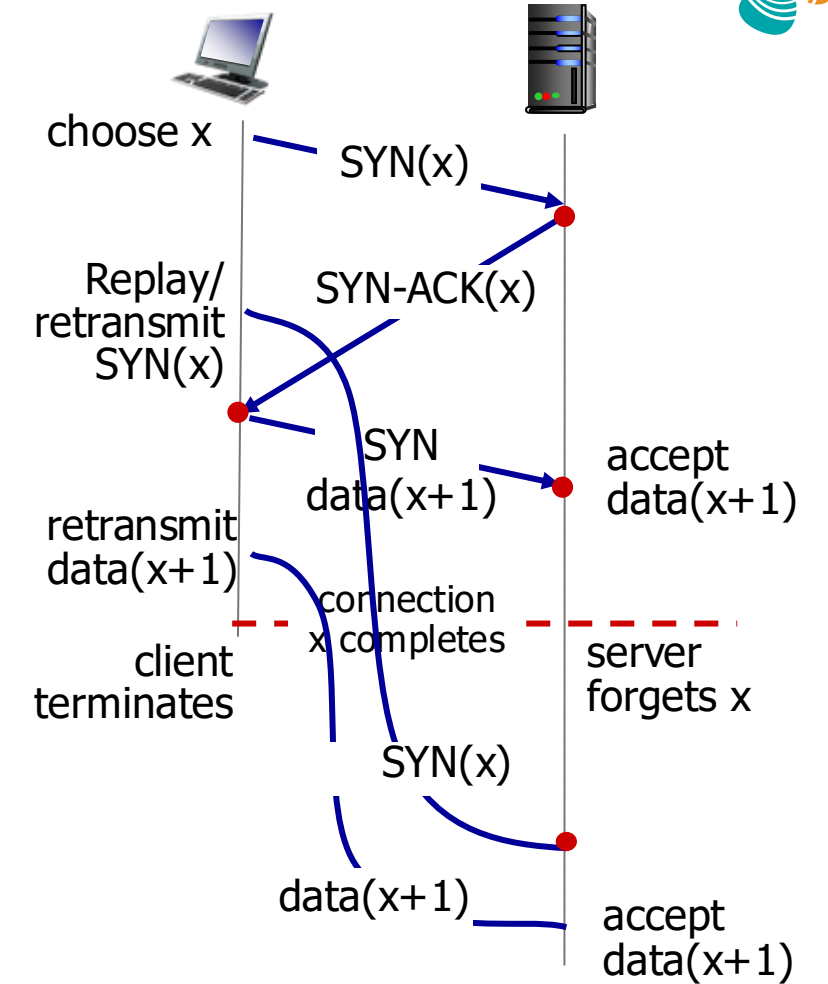


TCP handshake attack scenarios





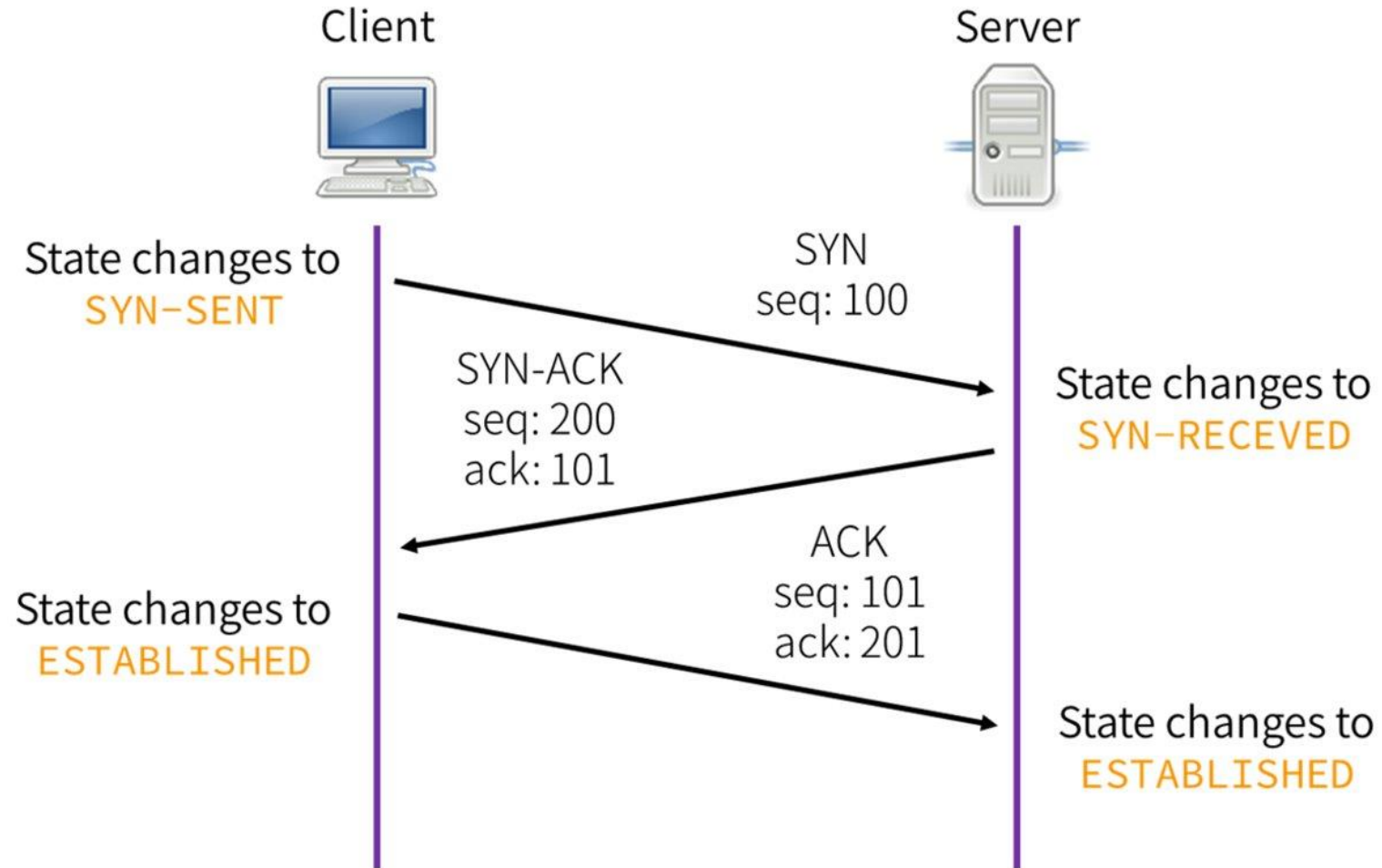
TCP handshake attack scenarios



Duplication (replay)



TCP 3-way handshake





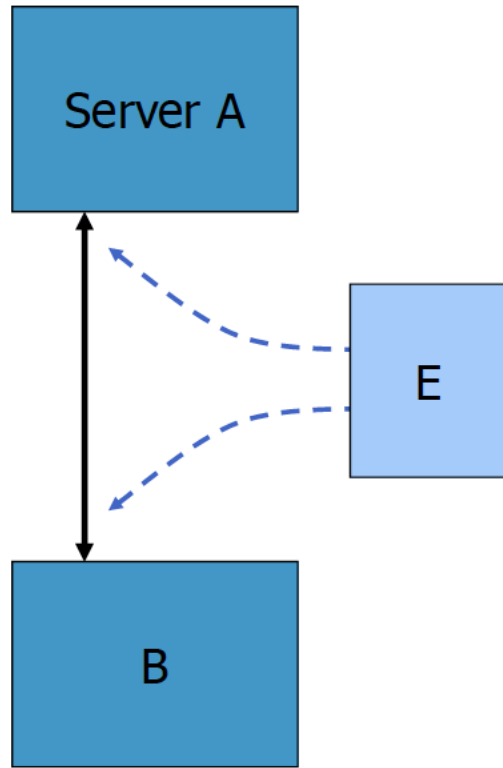
TCP sequence prediction attack



- Predict the sequence number used to identify the packets in a TCP connection, and then counterfeit packets.
- **Adversary**: do not have full control over the network, but can inject packets with fake source IP addresses
 - E.g., control a computer on the local network
- TCP sequence numbers are used for authenticating packets
- Initial seq# needs high degree of unpredictability
 - If attacker knows initial seq # and amount of traffic sent, can estimate likely current values
 - Some implementations are vulnerable



Blind TCP session hijacking



- A, B trusted connection
- E impersonates B to A
 - sends packets to A that resemble B's transmission
 - E cannot receive but may execute commands on A
- Risks
 - DoS
 - MITM attacks

Attack can be blocked if E is outside firewall



Too many Addresses in Internet



- Media Access Control (MAC) addresses in the network access layer

- Associated w/ network interface card (NIC)
- 48 bits or 64 bits

- IP addresses for the network layer

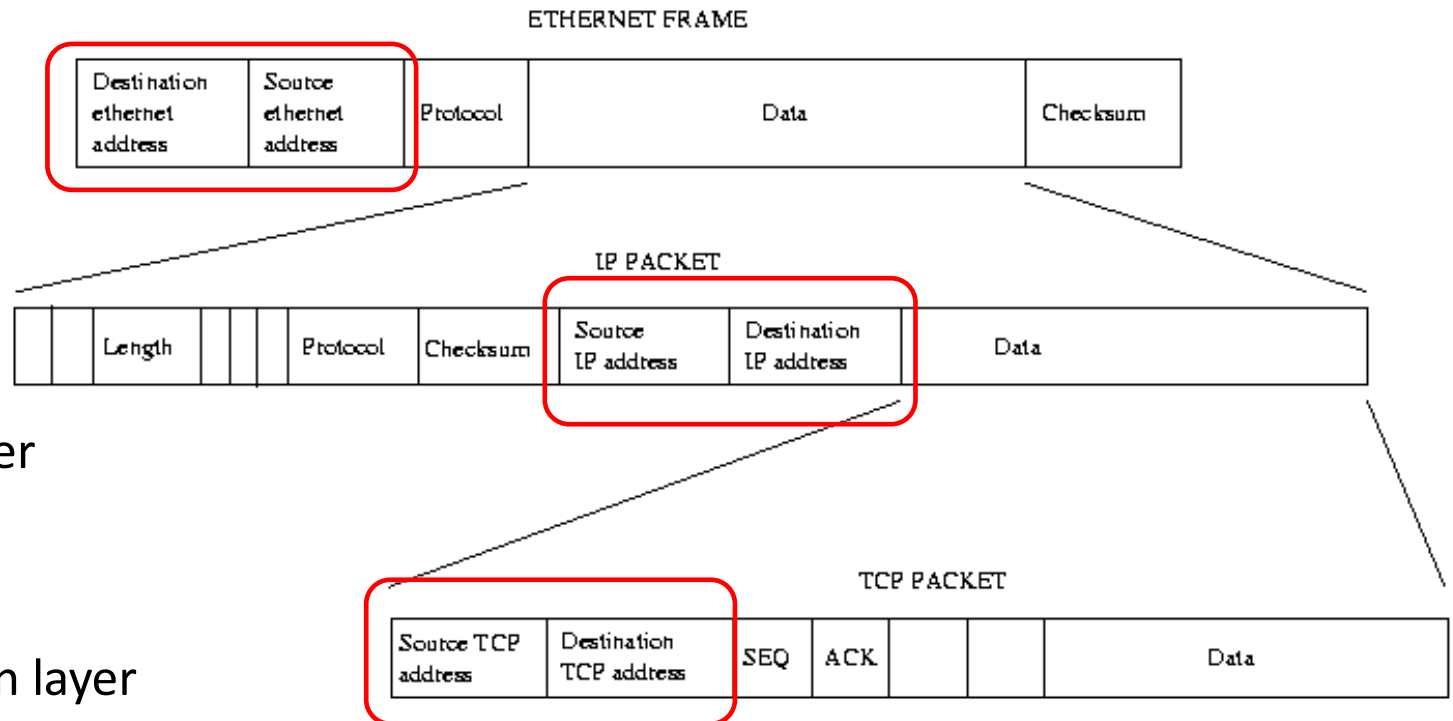
- 32 bits for IPv4, and 128 bits for IPv6
- E.g., 128.3.23.3

- IP addresses + ports for the transport layer

- E.g., 128.3.23.3:80

- Domain names for the application/human layer

- E.g., www.kaust.edu.sa





Routing and Translation of Addresses



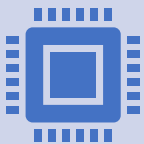
**Translation between IP addresses
and MAC addresses**

Address Resolution Protocol (ARP) for
IPv4
Neighbor Discovery Protocol (NDP) for
IPv6



Routing with IP Addresses

IP for routing packets
TCP/UDP multiplexing



**Translation between IP
addresses and domain names**

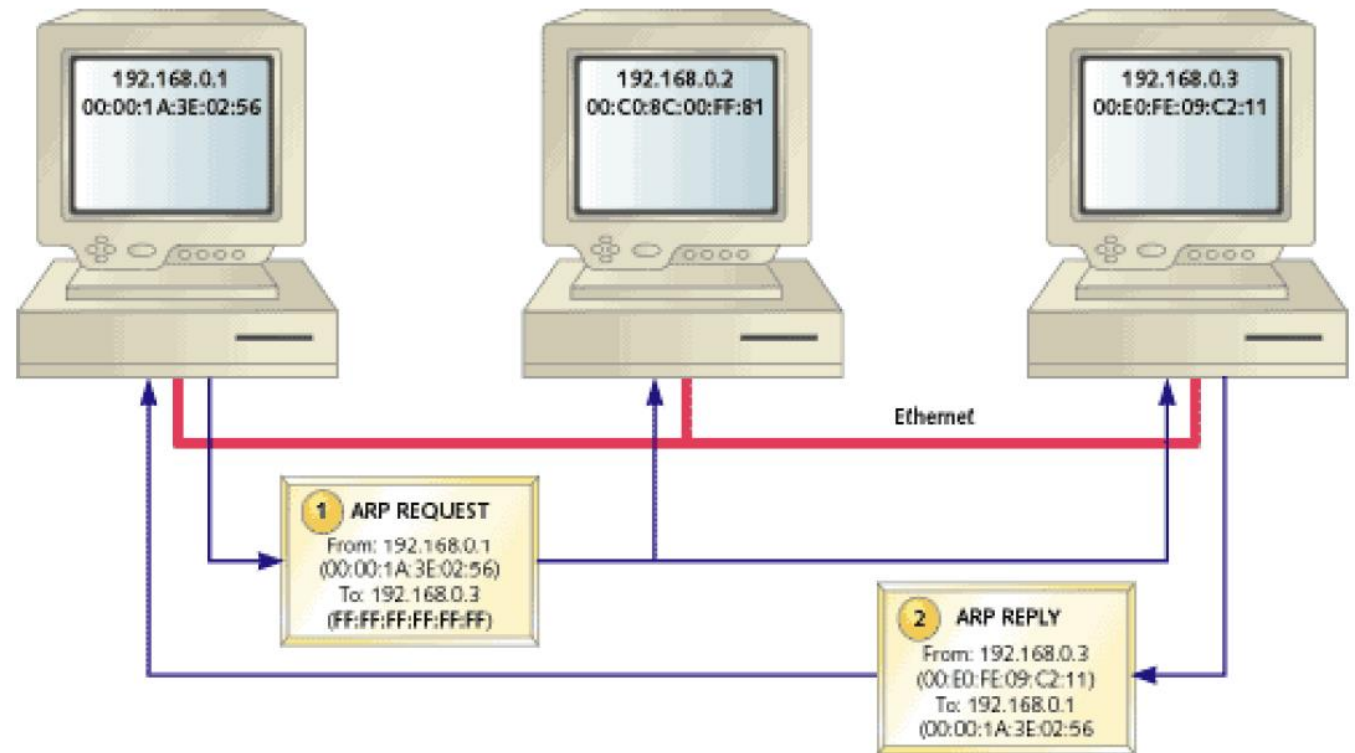
Domain Name System (DNS)
E.g., www.example.com →
192.0.2.1



Address Resolution Protocol (ARP)



- Primarily used to translate IP addresses to Ethernet MAC addresses
- Each host maintains a table of IP to MAC addresses
- Message types:
 - *ARP request*
 - *ARP reply*
 - *ARP announcement*





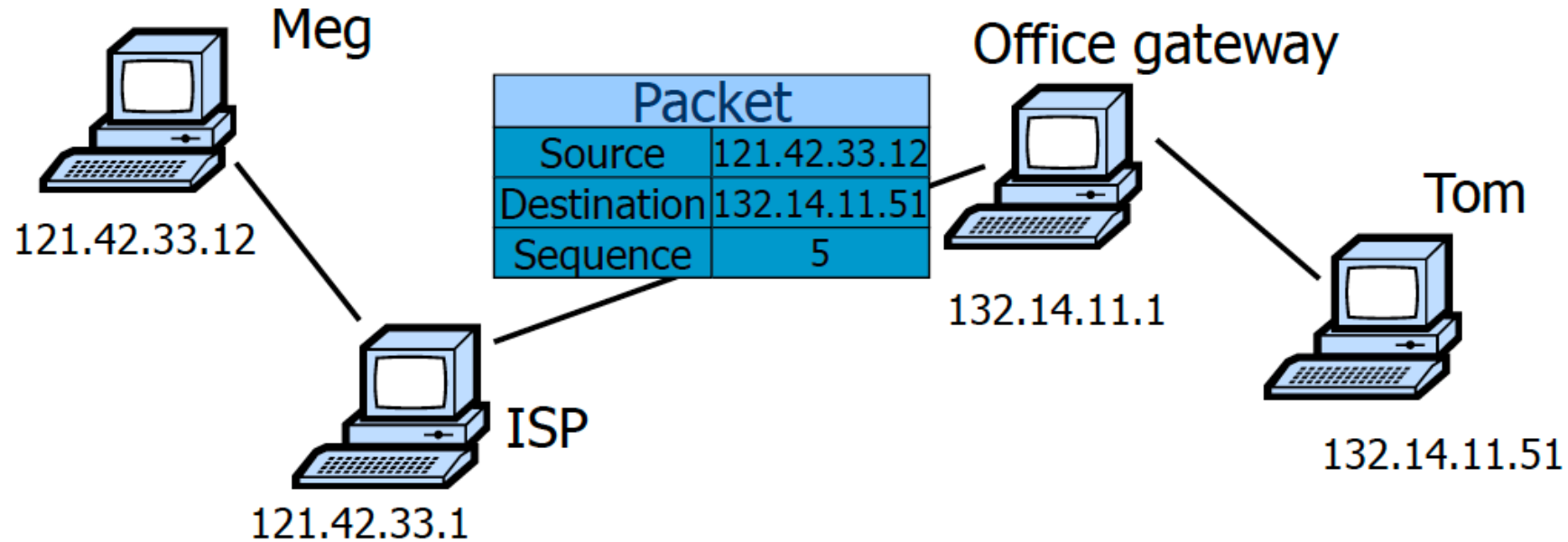
ARP Spoofing



- **Send fake or 'spoofed', ARP messages to an Ethernet LAN.**
 - *To have other machines associate IP addresses with the attacker's MAC*
- **Defenses**
 - *static ARP table*
 - *DHCP snooping (use access control to ensure that hosts only use the IP addresses assigned to them, and that only authorized DHCP servers are accessible).*
 - *detection: Arpwatch (sending email when updates occur),*
- **Legitimate use**
 - *redirect a user to a registration page before allow usage of the network*



IP Routing



- Internet routing uses numeric IP address
- Typical route uses several hops

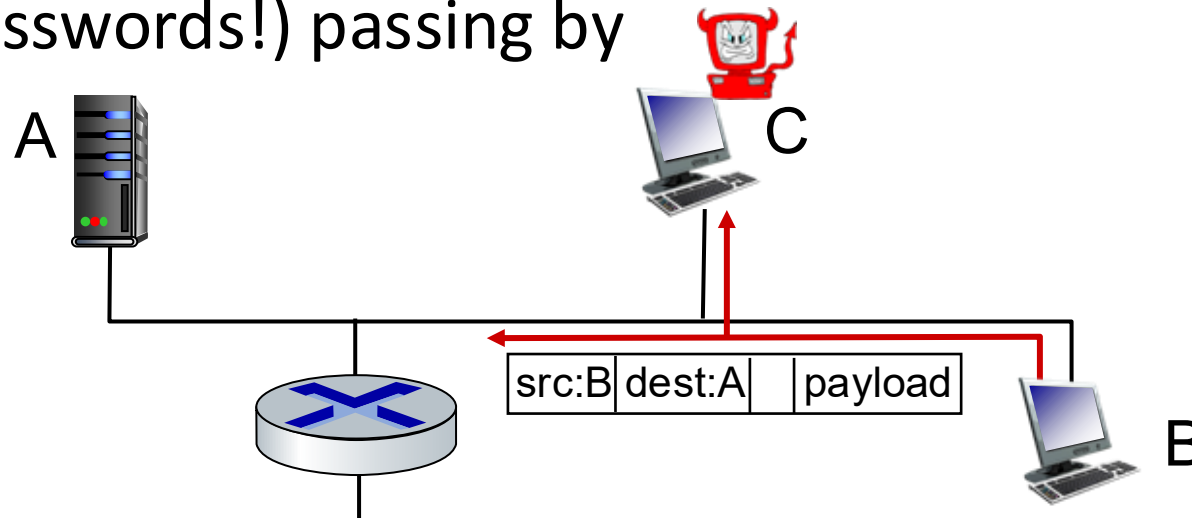


Bad guys: packet interception



packet “sniffing”:

- broadcast media (shared Ethernet, wireless)
- promiscuous network interface reads/records all packets (e.g., including passwords!) passing by



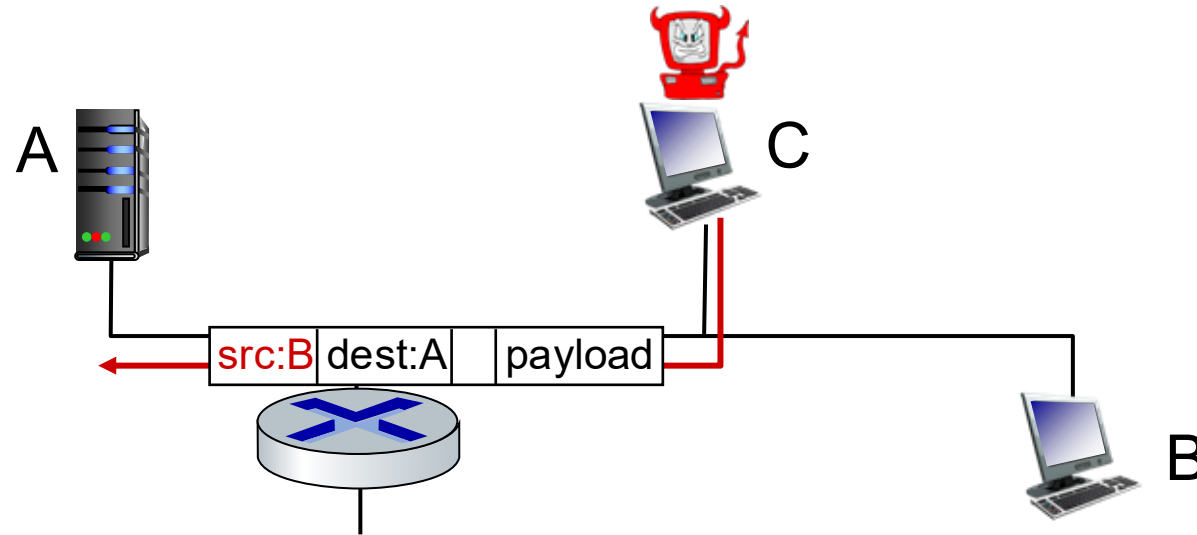
Prevention: Encryption (IPSEC, TLS)



Bad guys: fake identity

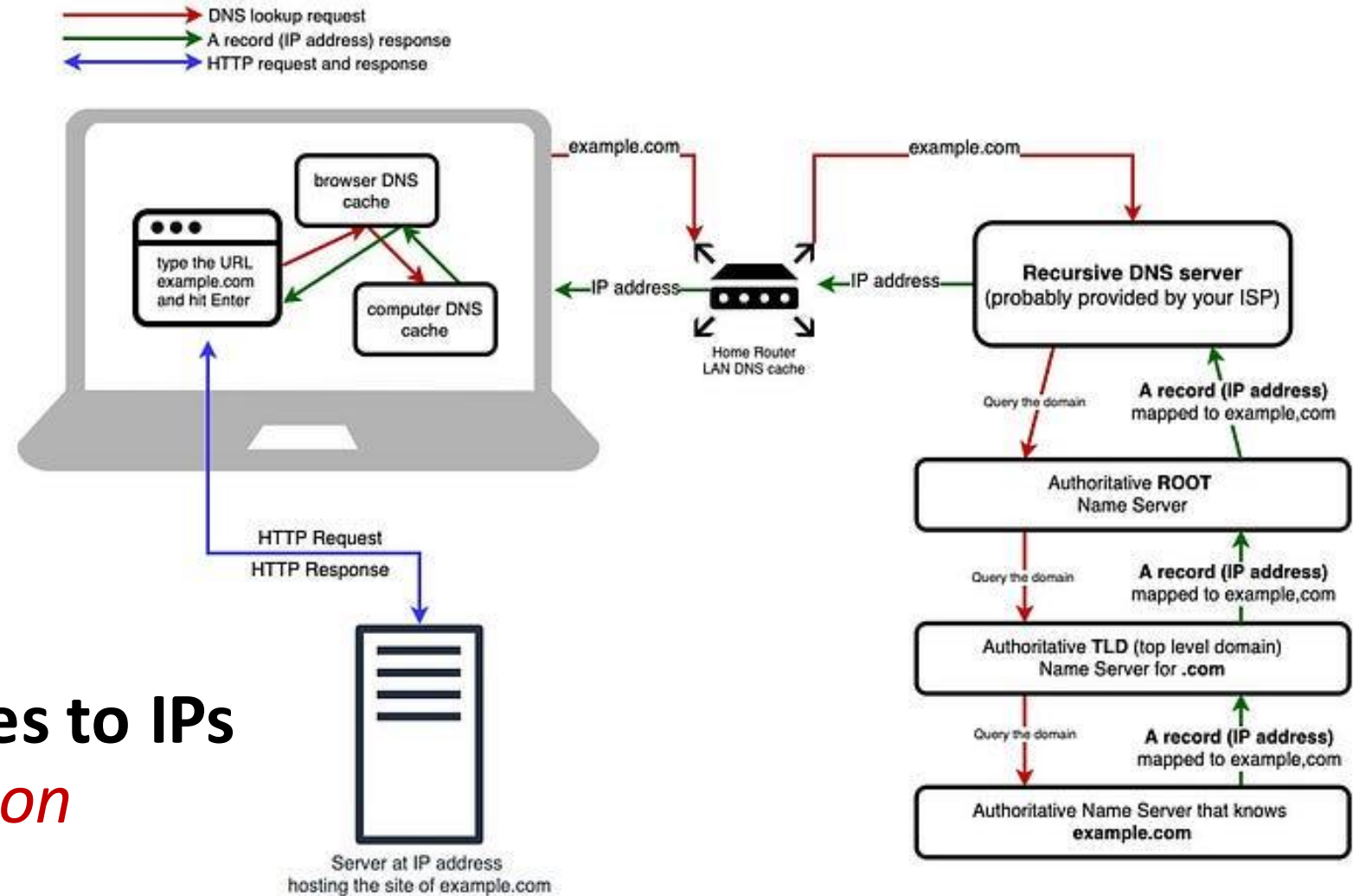


IP spoofing: injection of packet with false source address





Domain Name System - DNS



Maps domain names to IPs

More in the afternoon

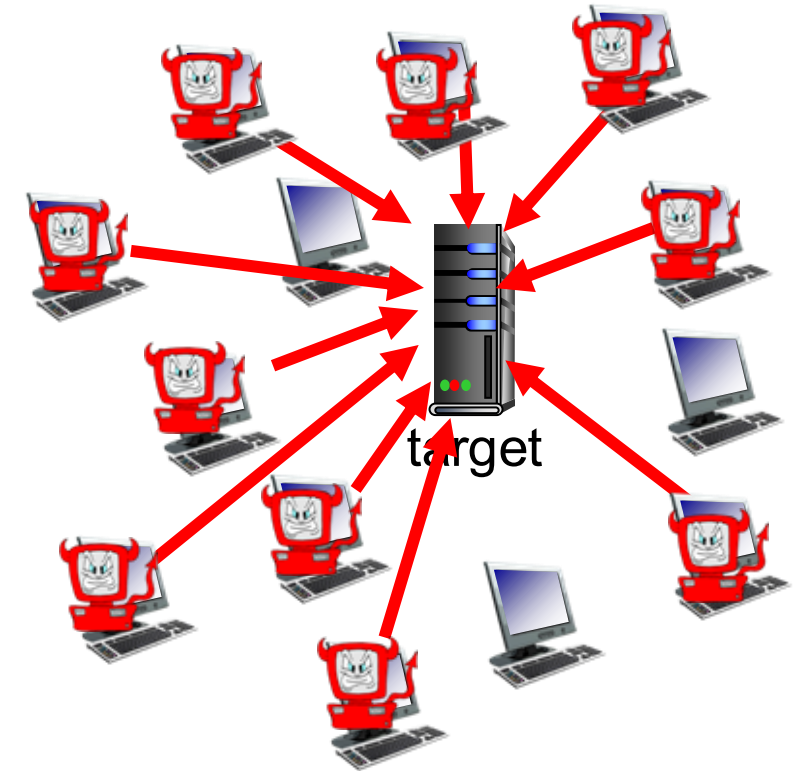


Bad guys: denial of service using DNS amplification



Denial of Service (DoS): attackers make resources (server, bandwidth) unavailable to legitimate traffic by overwhelming resource with bogus traffic

1. Spoof target's IP
2. Hack into Botnet and send DNS requests (UDP) using spoofed IP
3. DNS replies (large UDP) jam the spoofed target





Mapping Network Layers to Threats and Security Controls



Application Layer

Security Concerns

- Injection attacks (SQLi, Command Injection)
- XSS
- Broken authentication & authorization
- Insecure APIs
- Data leakage

Security Controls

- Secure coding practices
- Input validation & sanitization
- Authentication & authorization (MFA, OAuth)
- Web Application Firewall (WAF)
- Application logging & monitoring



Mapping Network Layers to Threats and Security Controls



Transport Layer (TCP)

Security Concerns

- Man-in-the-Middle (MITM)
- Session hijacking
- Replay attacks
- TCP SYN flooding (DoS)

Security Controls

- TLS / SSL (HTTPS)
- Secure session management
- Certificate validation
- Rate limiting & DoS protection



Mapping Network Layers to Threats and Security Controls



Network Layer (IP)

Security Concerns

- IP spoofing
- Routing attacks (e.g., BGP hijacking)
- Packet sniffing
- ICMP abuse

Security Controls

- IPsec (AH / ESP)
- Network firewalls
- Secure routing mechanisms
- Network segmentation



Mapping Network Layers to Threats and Security Controls



Link / Network Access Layer

Security Concerns

- ARP poisoning
- MAC spoofing
- Rogue devices
- VLAN hopping
- Physical access attacks

Security Controls

- Network Access Control (NAC)
- Port security
- Dynamic ARP inspection
- VLAN isolation
- Physical security controls



Case Study: WannaCry Ransomware Exploited SMB Protocol Vulnerability



Attack Profile

Date
May 12, 2017

Exploit
EternalBlue

Target Protocol
SMBv1 (Port 445)

Attribution
Lazarus Group

Global Impact

300k+

Computers

150+

Countries

\$4B+

Damages

Major Victims: NHS (UK), FedEx, Telefonica, Deutsche Bahn, Renault.

CRITICAL LESSON

The attack was preventable. Microsoft had released a patch (MS17-010) two months prior. Effective patch management is the first line of defense.

You became victim of the PETYA RANSOMWARE!

The haddisks of your computer have been encrypted with an Military grade encryption algorithm. There is no way to restore your data without a special key. You can purchase this key on the darknet page shown in step 2.

To purchase your key and restore your data, please follow these three easy steps:

1. Download the Tor Browser at "https://www.torproject.org/". If you need help, please google for "access onion page".
2. Visit one of the following pages with the Tor Browser:

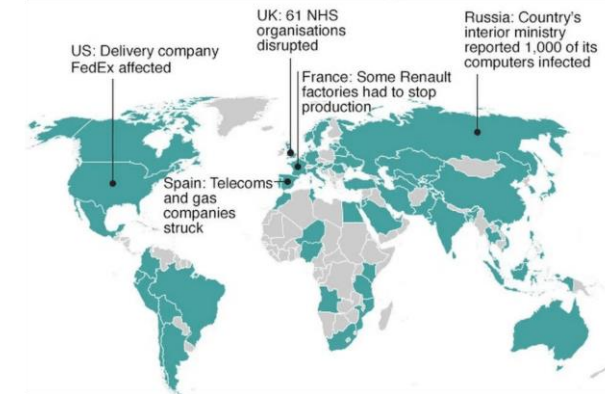
http://pety* .onion/g
http://pety* .onion/g
3. Enter your personal decryption code there:

aE nF

If you already purchased your key, please enter it below.

Key: _

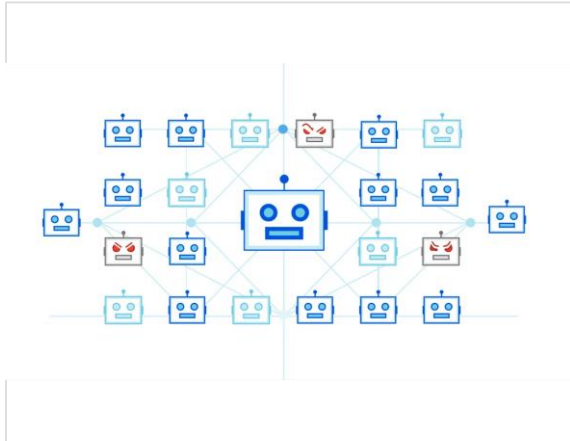
The infamous WannaCry ransom note appearing on infected systems



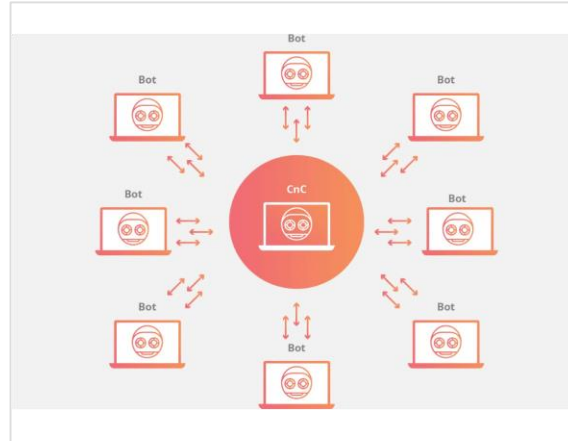
Global spread of the infection within 24 hours



Case Study: Mirai Botnet Weaponized IoT Devices for Record DDoS Attacks



Mirai Botnet Architecture



DDoS Attack Mechanism using IoT Devices

Attack Overview

Date

October 2016

Vector

IoT Default Creds

Target

Dyn DNS Provider

Devices

Cameras, DVRs, Routers

Scale & Impact

The attack took down major platforms including Netflix, Twitter, Reddit, and GitHub by overwhelming the DNS infrastructure.

620 Gbps (2016 Peak)

29.7 Tbps (2025 Variant)

CRITICAL LESSON

IoT devices are often shipped with insecure defaults. Changing default credentials and network segmentation are essential defenses.



Case Study: SolarWinds Supply Chain Attack Compromised 18,000 Organizations



Attack Profile

Timeline

Sept 2019 - Dec 2020

Method

SUNBURST Backdoor in Orion Updates

Attribution

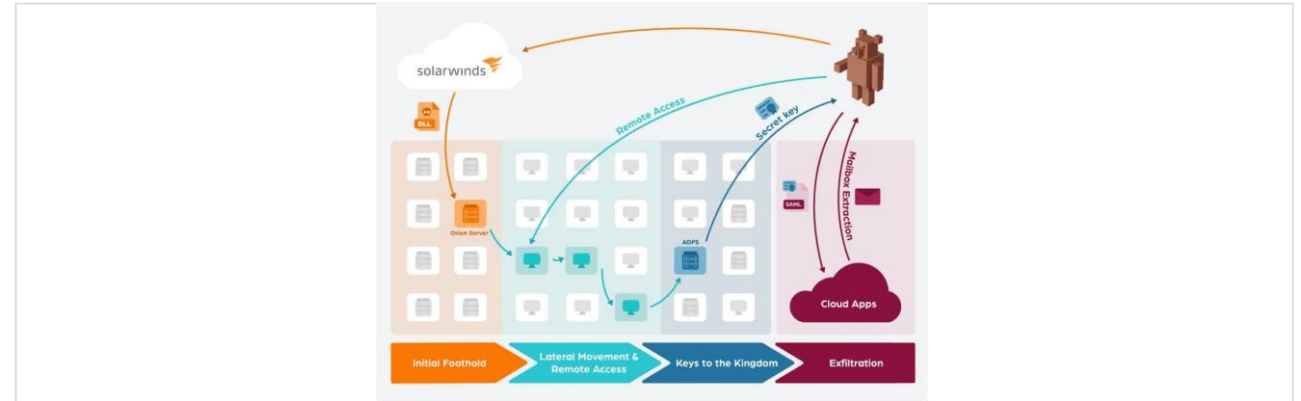
APT29 (Russian State-Sponsored)

High-Profile Victims

U.S. Treasury & Dept. of Homeland Security
Microsoft & FireEye
Multiple Fortune 500 Companies

CRITICAL LESSON

Traditional perimeter defenses fail against trusted software updates.
Zero Trust Architecture and supply chain verification are mandatory.



Attack Lifecycle: From Infiltration to Exfiltration



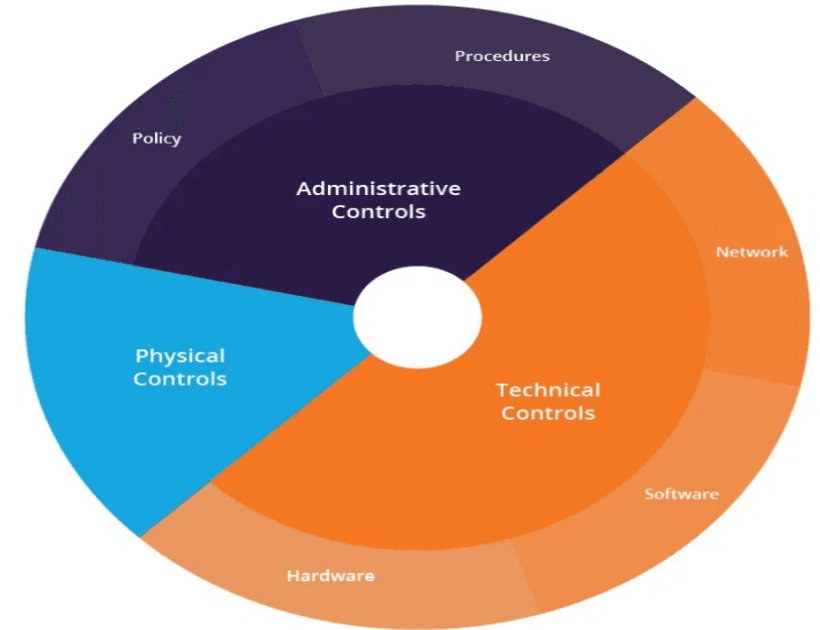
SUNBURST Backdoor Mechanism



Defense Strategies Must Address Each Layer of the TCP/IP Stack



Effective cybersecurity requires layered defenses tailored to the specific threats at each level. No single security control can protect against all attack vectors.



Defense in Depth Strategy



Best Practices for Securing TCP/IP Networks Against Modern Threats



Essential Security Practices

- 1 Patch Management**
Apply security updates promptly.
- 2 Network Segmentation**
Use VLANs and microsegmentation to contain breaches.
- 3 Encryption Everywhere**
Default to TLS/IPsec for data in transit.
- 4 Monitoring & Detection**
Deploy IDS/IPS and SIEM for real-time alerts.
- 5 Strong Authentication**
Enforce Multi-Factor Authentication (MFA).

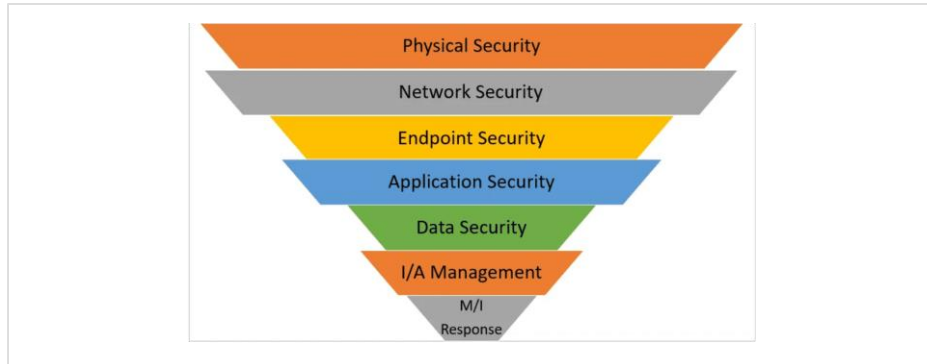
Operational Recommendations

Disable unnecessary services (Telnet, FTP)

Conduct regular penetration testing

Maintain incident response plans

Train users on security awareness



Defense in Depth: Multi-layered Security Approach

Zero Trust Architecture

"Never trust, always verify." Assume breach and verify each connection before granting access.



Security Protocols Provide Encryption and Authentication Across Layers

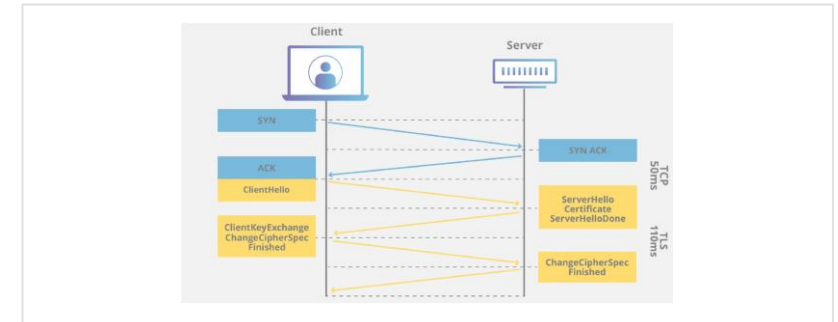


Security protocols add confidentiality, integrity, and authentication to network communications. Understanding where they operate is essential for comprehensive defense.

Layer	Protocol	Function
Application	TLS/SSL, SSH	Encrypts web, email, and app traffic; secure remote access.
Transport	TLS 1.3	Session encryption with forward secrecy.
Internet	IPsec	Packet-level encryption and authentication (VPNs).
Network Access	WPA3, 802.1X	Wi-Fi encryption and port-based access control.

Defense in Depth

Attackers target the weakest link. Implementing security protocols at multiple layers ensures that if one fails, others remain to protect the data.



TLS Handshake Process



IPsec Tunnel Mode



Key Takeaways - TCP/IP Security Requires Layered Defense Strategy



Comprehensive Security Model

Core Principles

- Each layer has unique vulnerabilities requiring tailored defenses.
- Attackers often chain exploits across multiple layers (e.g., Phishing → Malware → Lateral Movement).
- Defense in Depth is essential; no single control is sufficient.

Layer Defense Recap

Application

Secure Coding, Encryption, User Awareness

Transport

Rate Limiting, TLS, Session Management

Internet

IPsec, Filtering, DDoS Protection

Network Access

Segmentation, Port Security, Physical Controls

Final Thought

The TCP/IP model was designed for connectivity, not security. Modern cybersecurity professionals must add security at every layer to protect against evolving threats.



Lines of defense



- **authentication:** proving you are who you say you are
 - cellular networks provides hardware identity via SIM card; no such hardware assist in traditional Internet
- **confidentiality:** via encryption
- **integrity checks:** digital signatures prevent/detect tampering
- **access restrictions:** password-protected VPNs
- **firewalls:** specialized “middleboxes” in access and core networks:
 - off-by-default: filter incoming packets to restrict senders, receivers, applications
 - detecting/reacting to DOS attacks



Questions & Discussion



Discussion Topics

IoT & The Attack Surface

How does the rise of insecure IoT devices change the threat model for the Network Access Layer?

Zero Trust vs. Legacy

What practical challenges do organizations face when adopting Zero Trust in legacy TCP/IP environments?

AI in Offense & Defense

How will AI-driven automation affect attack speed and the need for automated defenses?

Recommended Resources

NIST Cybersecurity Framework (CSF)

Guidelines for managing cybersecurity risk.

OWASP Top 10

Awareness document for web application security.

CIS Critical Security Controls

Prioritized actions to protect organizations from common attack vectors.

"TCP/IP Illustrated, Vol. 1"

by W. Richard Stevens

Do you have any questions?



rc3.kaust.edu.sa



Follow us @rc3kaust

